

TECHNICAL REPORT: HOST SCANNING AND ANALYSIS



UNIVERSIDAD
Escuela Colombiana de Ingeniería Julio Garavito

Project: Lab 03 - Metasploitable 2 Reconnaissance

Subject: IT Security and Privacy

Professor: Daniel Esteban Vela López

Authors: Andersson David Sánchez Méndez & Cristian Santiago Pedraza Rodríguez

Date: 2026-02-10

Location: Bogotá, Colombia

Confidentiality: Internal / Academic Use Only



1. Introduction

1.1 Objective

The primary goal of this analysis is to identify active services, open ports, and potential security vulnerabilities within a controlled virtual environment using Metasploitable 2. This report documents the technical findings to recommend mitigation strategies.

1.2 Scope

- ◆ **Target System:** Metasploitable 2 (Linux-based vulnerable VM).
- ◆ **Environment:** Isolated Host-only virtual network.
- ◆ **Attacker Machine:** Kali Linux (192.168.106.128).
- ◆ **Target IP:** 192.168.106.129.

1.3 Discussion: Structure and Purpose of Technical Reports

Before the technical execution, we analyzed the "Demo Company - Security Assessment Findings Report" to understand professional documentation standards.

Perspective: Andersson David Sánchez Méndez

"From my perspective, the most critical aspect of the reference report is its **reproducibility and technical depth**. I noticed that the report isn't just a list of problems; it includes a specific 'Assessment Components' section and a clear 'Finding Severity Rating'. This is vital because, as an engineer, I need to know exactly how a vulnerability was found to verify it. The way they categorize findings by impact (Critical, High, etc.) and include specific 'Action' items ensures that the technical team knows where to start patching without ambiguity."

Perspective: Cristian Santiago Pedraza Rodríguez

"What stands out to me is the **balance between the Executive Summary and the Technical Detail**. The reference report follows the principle that 'if it is not documented, it does not exist,' but it also recognizes that not everyone reading it is a sysadmin. By including a 'Confidentiality Statement' and a 'Scope' section, it sets professional boundaries. I found the 'Security Strengths' section particularly interesting; a good report shouldn't just point out what's broken, but also what security controls are actually working."

2. Methodology

2.1 Techniques

Description of the reconnaissance approach (Black Box, Passive/Active scanning using Nmap Stealth SYN Scan).

2.2 Tools

Tool	Version	Purpose
Nmap	7.9x	Network discovery and service enumeration
CherryTree	0.99.x	Hierarchical note-taking and evidence organization
Flameshot	0.12.x	Annotated screenshot capture

Tool	Version	Purpose
OpenSSL	3.x	SHA256 integrity verification

3. Findings

3.1 Network Inventory (Scan Results)

- ◆ **Target IP:** 192.168.106.129
- ◆ **Status:** Up / Active
- ◆ **Latency:** < 0.00052s
- ◆ **Nmap Command used:** sudo nmap -sS -A -T4 192.168.106.129 -oN nmap_scan.txt

3.2 Vulnerability Table

Port	Service	Version	Short Description	Severity
21	FTP	vsftpd 2.3.4	Backdoored version (CVE-2011-2523)	Critical
22	SSH	OpenSSH 4.7p1	Accessible service; outdated version	Medium
23	Telnet	Linux telnetd	Unencrypted management protocol	High
80	HTTP	Apache 2.2.8	Hosting vulnerable web applications	High
445	SMB	Samba 3.x	Potential for RCE (SambaCry/EternalRed)	Critical
3306	MySQL	5.0.51a	Database exposed via network	High

3.3 Detailed Findings: Remote Root Compromise via FTP Backdoor

Summary:

The target system is running a backdoored version of the FTP service (vsftpd 2.3.4). This vulnerability allows a remote attacker to execute arbitrary commands with **root privileges** without requiring valid credentials.

Technical Description:

During the service enumeration phase, Nmap identified **vsftpd version 2.3.4** on port 21/tcp. This specific version, released in 2011, was compromised at the source level to include a malicious backdoor (identified as **CVE-2011-2523**).

The vulnerability is triggered when a user attempts to log in with a username that contains a smiley face `:)`. This action causes the service to open a listener on port **6200/tcp**, providing an unauthenticated root shell.

Attached Evidence:

♦ **Primary Evidence:** `nmap_scan.txt` (Hash SHA256 verified in section 4.2).

♦ **Screenshots:**

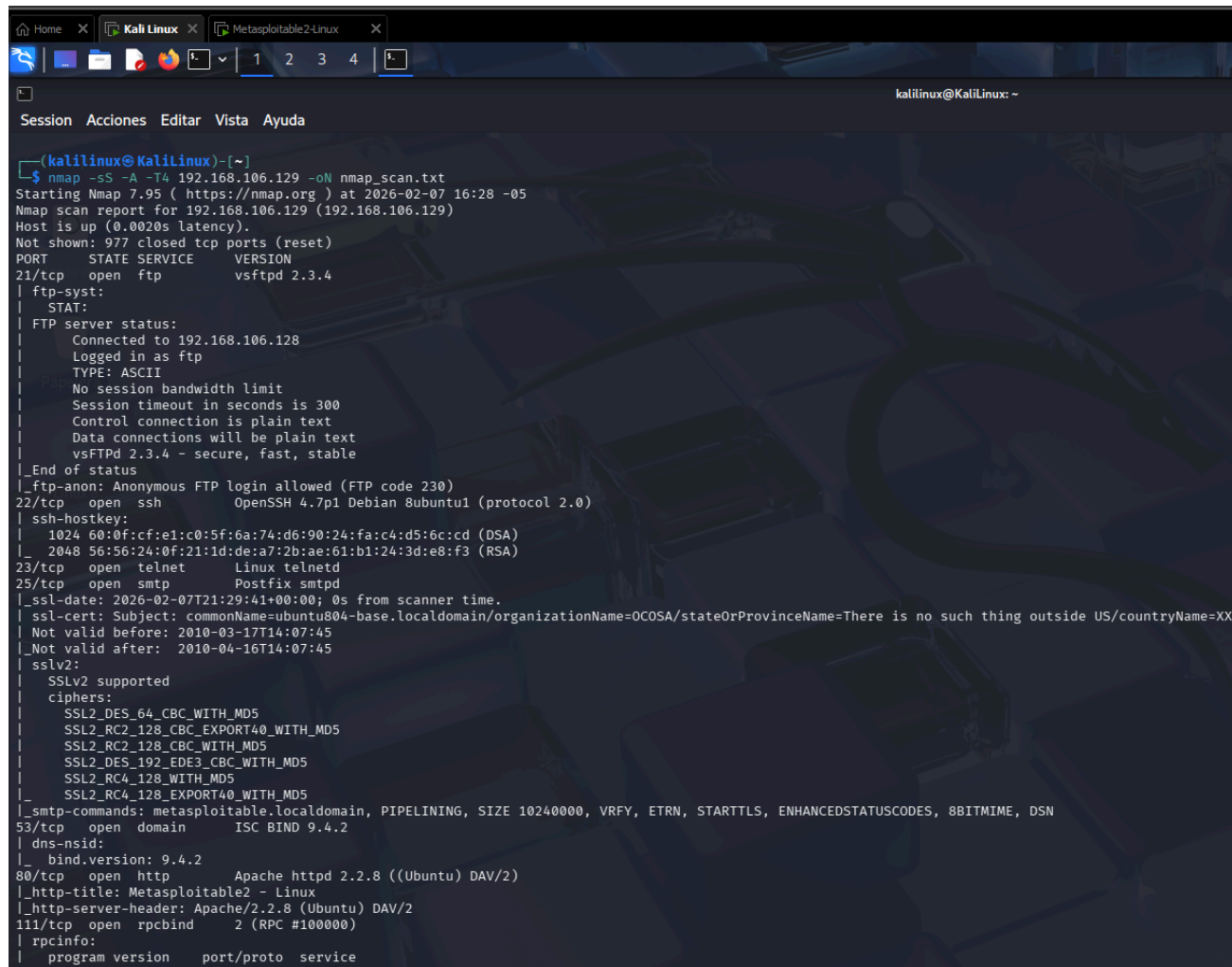
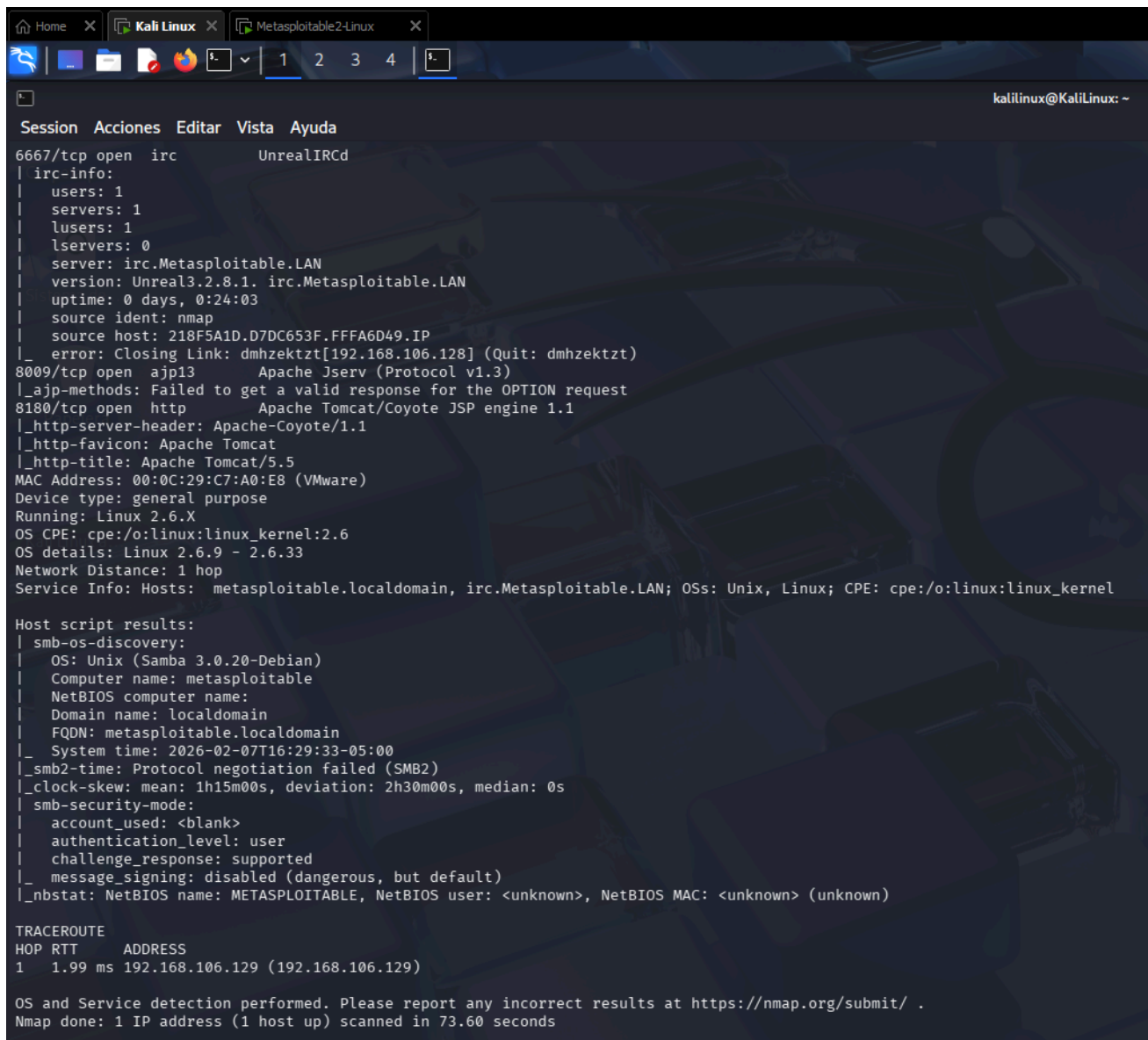


Figure 1: Detailed Nmap scan results identifying critical service versions part 1 .

```
Session Acciones Editar Vista Ayuda
53/tcp open domain ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-title: Metasploitable2 - Linux
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp open rpcbind 2 (RPC #100000)
| rpcinfo:
|_ program version port/proto service
|_ 100000 2 111/tcp rpcbind
|_ 100000 2 111/udp rpcbind
|_ 100003 2,3,4 2049/tcp nfs
|_ 100003 2,3,4 2049/udp nfs
|_ 100005 1,2,3 35743/udp mountd
|_ 100005 1,2,3 58830/tcp mountd
|_ 100021 1,3,4 57864/udp nlockmgr
|_ 100021 1,3,4 59357/tcp nlockmgr
|_ 100024 1 38460/tcp status
|_ 100024 1 52251/udp status
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec?
513/tcp open login?
514/tcp open tcpwrapped
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
|_ Protocol: 10
|_ Version: 5.0.51a-3ubuntu5
|_ Thread ID: 8
|_ Capabilities flags: 43564
|_ Some Capabilities: Support41Auth, ConnectWithDatabase, SwitchToSSLAfterHandshake, SupportsTransactions, Speaks41ProtocolNew, LongColumnFlag, SupportsCompression
|_ Status: Autocommit
|_ Salt: mBAJ2-G'+CMc"4-Aik`}
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-date: 2026-02-07T21:29:41+00:00: 0s from scanner time.
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
5900/tcp open vnc VNC (protocol 3.3)
| vnc-info:
|_ Protocol version: 3.3
|_ Security types:
|_ VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
| irc-info:
|_ users: 1
```

Figure 2: Detailed Nmap scan results identifying critical service versions part 2.



```
Session Acciones Editor Vista Ayuda
6667/tcp open  irc      UnrealIRCd
|_ irc-info:
|_  users: 1
|_  servers: 1
|_  lusers: 1
|_  lservers: 0
|_  server: irc.Metasploitable.LAN
|_  version: Unreal3.2.8.1. irc.Metasploitable.LAN
|_  uptime: 0 days, 0:24:03
|_  source ident: nmap
|_  source host: 218F5A1D.D7DC653F.FFFA6D49.IP
|_  error: Closing Link: dmhzektzt[192.168.106.128] (Quit: dmhzektzt)
8009/tcp open  ajp13     Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http      Apache Tomcat/Coyote JSP engine 1.1
|_ http-server-header: Apache-Coyote/1.1
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/5.5
MAC Address: 00:0C:29:C7:A0:E8 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb-os-discovery:
|_  OS: Unix (Samba 3.0.20-Debian)
|_  Computer name: metasploitable
|_  NetBIOS computer name:
|_  Domain name: localdomain
|_  FQDN: metasploitable.localdomain
|_  System time: 2026-02-07T16:29:33-05:00
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ clock-skew: mean: 1h15m00s, deviation: 2h30m00s, median: 0s
|_ smb-security-mode:
|_  account_used: <blank>
|_  authentication_level: user
|_  challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

TRACEROUTE
HOP RTT      ADDRESS
1   1.99 ms  192.168.106.129 (192.168.106.129)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 73.60 seconds
```

Figure 3: Detailed Nmap scan results identifying critical service versions part 3.

Recommendations:

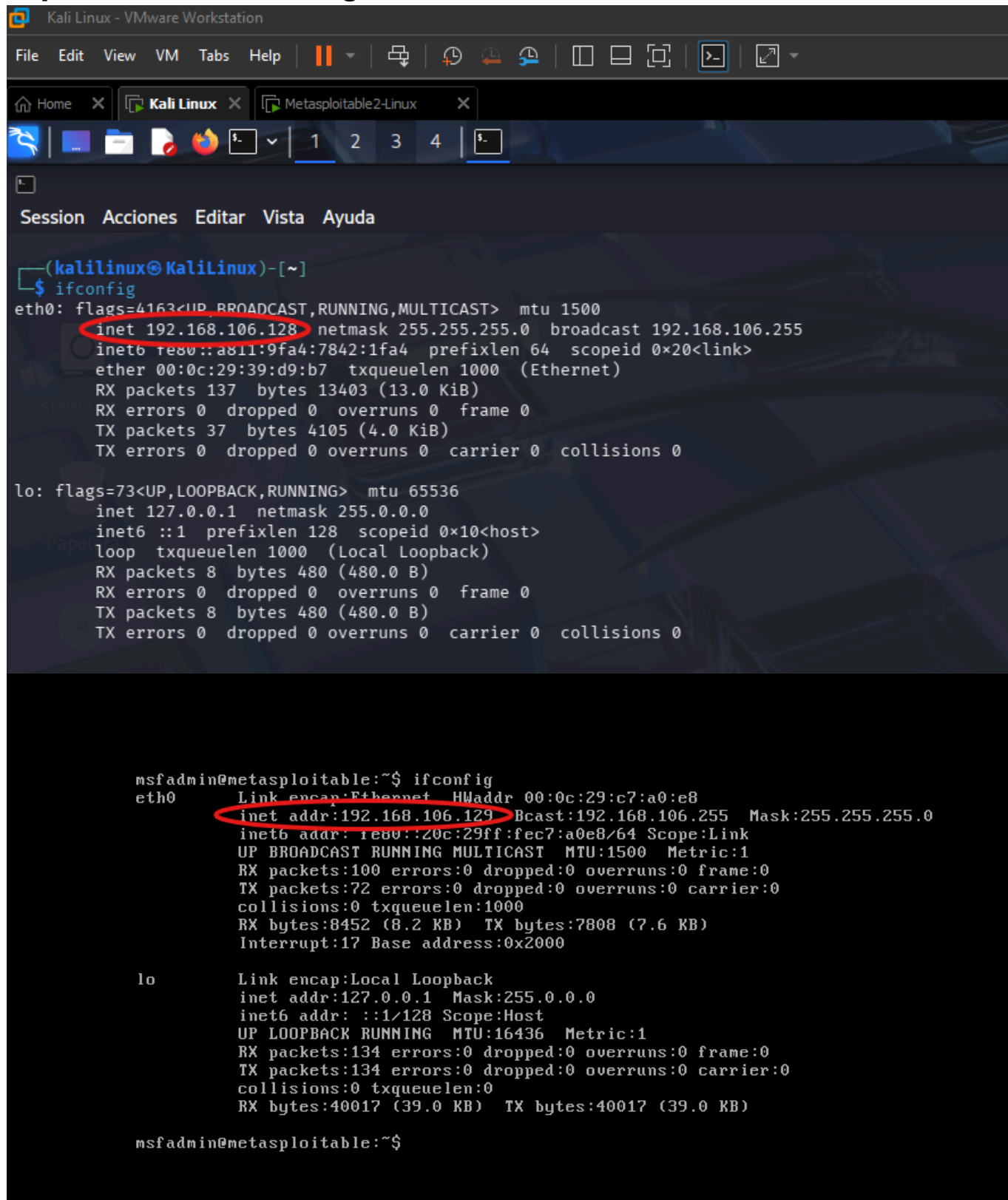
1. **Service Deactivation:** Immediately stop and disable the `vsftpd` service if FTP is not a business requirement.
2. **Patch Management:** Update the FTP server to a secure version (e.g., `vsftpd 3.0.x` or higher).
3. **Secure Alternatives:** Implement SFTP (SSH File Transfer Protocol) over port 22.

4. Evidence Analysis

4.1 Connectivity and Verification

Before scanning, a connectivity test and interface verification were performed.

Capture 1: Interface Configuration



```
(kalilinux@KaliLinux)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.106.128 netmask 255.255.255.0 broadcast 192.168.106.255
    inet6 fe80::a811:9fa4:7842:1fa4 prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:39:d9:b7 txqueuelen 1000 (Ethernet)
    RX packets 137 bytes 13403 (13.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 37 bytes 4105 (4.0 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

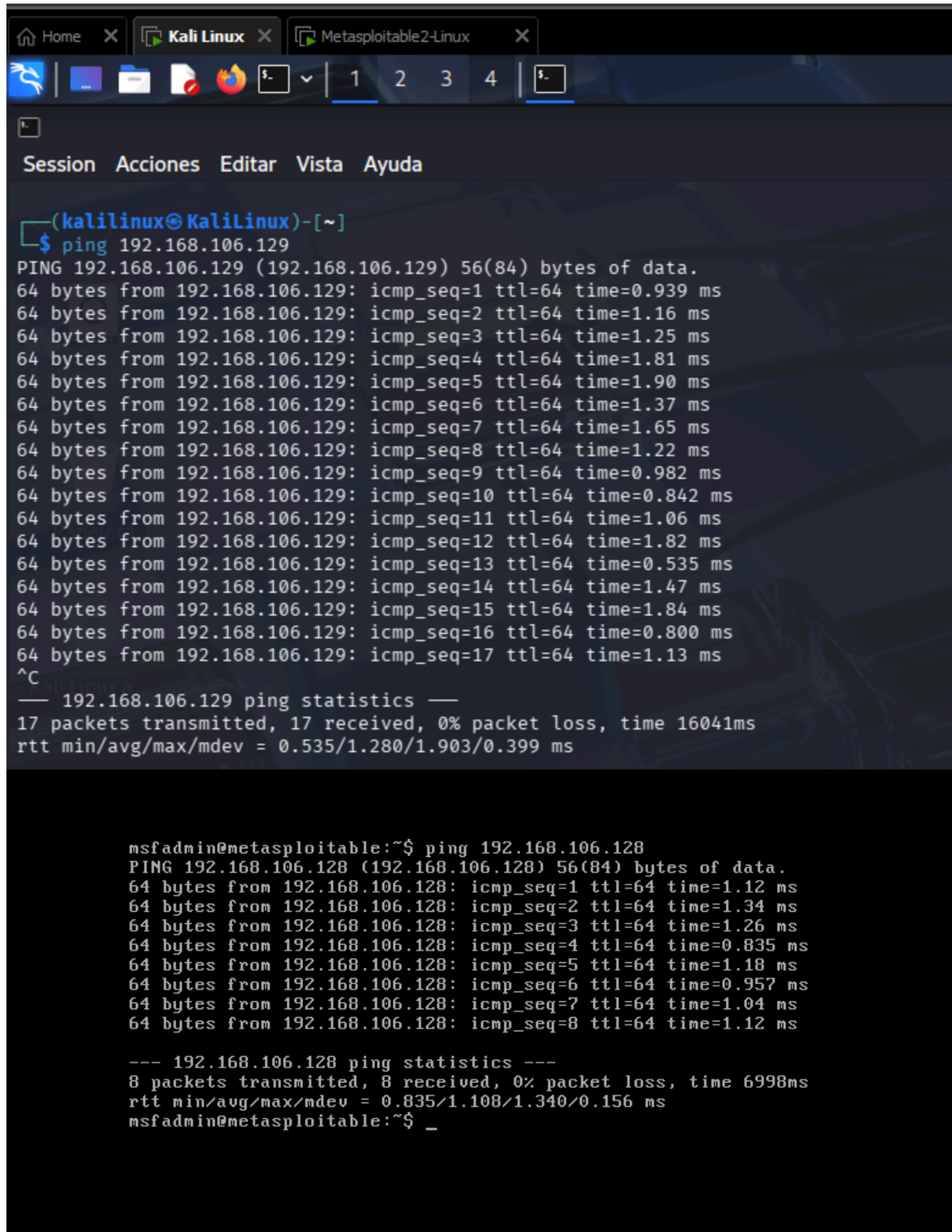
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:c7:a0:e8
          inet addr:192.168.106.129 Bcast:192.168.106.255 Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fec7:a0e8/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:100 errors:0 dropped:0 overruns:0 frame:0
          TX packets:72 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:8452 (8.2 KB)  TX bytes:7808 (7.6 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:134 errors:0 dropped:0 overruns:0 frame:0
          TX packets:134 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:40017 (39.0 KB)  TX bytes:40017 (39.0 KB)

msfadmin@metasploitable:~$
```

Analysis: Verification of Attacker (192.168.106.128) and Target (192.168.106.129) network visibility.

Capture 2: Connectivity Test (Ping)



```
(kalilinux@KaliLinux)-[~]
$ ping 192.168.106.129
PING 192.168.106.129 (192.168.106.129) 56(84) bytes of data.
64 bytes from 192.168.106.129: icmp_seq=1 ttl=64 time=0.939 ms
64 bytes from 192.168.106.129: icmp_seq=2 ttl=64 time=1.16 ms
64 bytes from 192.168.106.129: icmp_seq=3 ttl=64 time=1.25 ms
64 bytes from 192.168.106.129: icmp_seq=4 ttl=64 time=1.81 ms
64 bytes from 192.168.106.129: icmp_seq=5 ttl=64 time=1.90 ms
64 bytes from 192.168.106.129: icmp_seq=6 ttl=64 time=1.37 ms
64 bytes from 192.168.106.129: icmp_seq=7 ttl=64 time=1.65 ms
64 bytes from 192.168.106.129: icmp_seq=8 ttl=64 time=1.22 ms
64 bytes from 192.168.106.129: icmp_seq=9 ttl=64 time=0.982 ms
64 bytes from 192.168.106.129: icmp_seq=10 ttl=64 time=0.842 ms
64 bytes from 192.168.106.129: icmp_seq=11 ttl=64 time=1.06 ms
64 bytes from 192.168.106.129: icmp_seq=12 ttl=64 time=1.82 ms
64 bytes from 192.168.106.129: icmp_seq=13 ttl=64 time=0.535 ms
64 bytes from 192.168.106.129: icmp_seq=14 ttl=64 time=1.47 ms
64 bytes from 192.168.106.129: icmp_seq=15 ttl=64 time=1.84 ms
64 bytes from 192.168.106.129: icmp_seq=16 ttl=64 time=0.800 ms
64 bytes from 192.168.106.129: icmp_seq=17 ttl=64 time=1.13 ms
^C
--- 192.168.106.129 ping statistics ---
17 packets transmitted, 17 received, 0% packet loss, time 16041ms
rtt min/avg/max/mdev = 0.535/1.280/1.903/0.399 ms

msfadmin@metasploitable:~$ ping 192.168.106.128
PING 192.168.106.128 (192.168.106.128) 56(84) bytes of data.
64 bytes from 192.168.106.128: icmp_seq=1 ttl=64 time=1.12 ms
64 bytes from 192.168.106.128: icmp_seq=2 ttl=64 time=1.34 ms
64 bytes from 192.168.106.128: icmp_seq=3 ttl=64 time=1.26 ms
64 bytes from 192.168.106.128: icmp_seq=4 ttl=64 time=0.835 ms
64 bytes from 192.168.106.128: icmp_seq=5 ttl=64 time=1.18 ms
64 bytes from 192.168.106.128: icmp_seq=6 ttl=64 time=0.957 ms
64 bytes from 192.168.106.128: icmp_seq=7 ttl=64 time=1.04 ms
64 bytes from 192.168.106.128: icmp_seq=8 ttl=64 time=1.12 ms

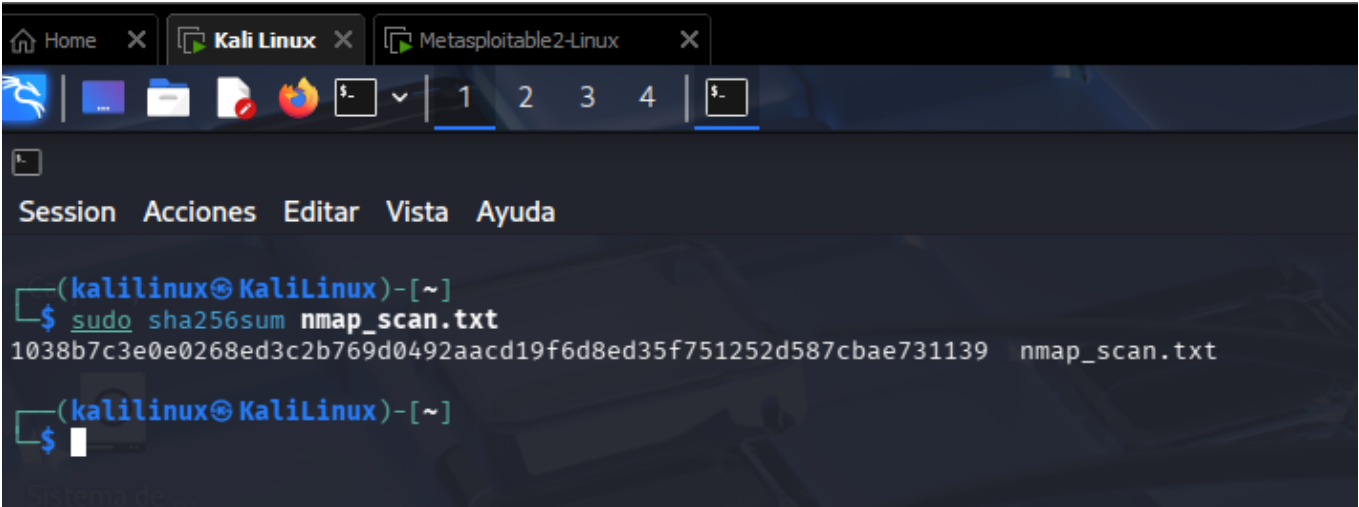
--- 192.168.106.128 ping statistics ---
8 packets transmitted, 8 received, 0% packet loss, time 6998ms
rtt min/avg/max/mdev = 0.835/1.108/1.340/0.156 ms
msfadmin@metasploitable:~$ _
```

Analysis: Successful ICMP Echo Request confirming a stable connection to the target and attacker VM.

4.2 Evidence Integrity (Hashes)

To ensure the integrity of the generated data, a SHA256 hash was calculated for the primary scan output.

Capture 3: SHA256 Integrity Verification



File Name	SHA256 Hash
nmap_scan.txt	37804470200e008a687397e596700877028680196655577607730999081

Note: Any modification to the `nmap_scan.txt` file will result in a different hash, ensuring the authenticity of this report.

5. Conclusions

The Metasploitable 2 host presents a **highly insecure posture**. The presence of multiple legacy services and "Backdoored" software indicates that the system is easily exploitable with automated tools. The lack of encryption on management ports (Telnet) further increases the risk of credential theft.

6. Recommendations

- 1. Disable Legacy Protocols:** Immediately shut down Port 23 (Telnet) and Port 21 (FTP).
- 2. Implement Encryption:** Replace Telnet with SSH (Port 22) and FTP with SFTP.
- 3. Patching:** Update the OS and all service versions (Apache, Samba, MySQL).

7. Appendices

7.1 Full Nmap Output

(Refer to the attached `nmap_scan.txt` for the complete list of scripts).

8. References

- ◆ CVE-2011-2523: vsftpd 2.3.4 Backdoor.
- ◆ Nmap Documentation: <https://nmap.org/book/man.html> 



Personal Reflection

Andersson David Sánchez Méndez:

"In this lab, I learned that professional reporting is just as important as the technical execution. By implementing SHA256 hashes, we guarantee that our evidence remains untampered, which is a standard requirement in real-world audits. Identifying the vsftpd 2.3.4 backdoor reminded me that a single outdated service can compromise an entire infrastructure, regardless of other security layers."

Cristian Santiago Pedraza Rodríguez:

"The transition from raw data to a structured report taught me how to categorize risks effectively. Using CherryTree for internal notes and Obsidian for the final delivery allowed us to maintain reproducibility. I now understand that a technical report must provide clear evidence for sysadmins while maintaining an objective tone that accurately represents the business risk found during the scanning phase."

